

Modificacion de procesos de monitoreo

Divier Jácamo Álvarez

Cetav La Libertad

Fecha: Martes 24/03/26

Corrección de procesos

Introducción

Los SOC son fundamentales para detectar y responder a ataques cibernéticos mi documento describe un modelo integral de vigilancia que permite gestionar adecuadamente los eventos de seguridad, asegurando una detección temprana, un análisis contextual y un manejo eficiente de incidentes.

Arquitectura del SOC

La infraestructura se basa en un modelo centralizado que cuenta con un sistema SIEM, el cual integra diversas fuentes de información:

Dispositivos de seguridad de red

Soluciones de protección para endpoints Servidores y sistemas operativos críticos

Sistemas de autenticación Infraestructura de red y segmentación

Flujo de Procesamiento de Información

Recolección: Registros en formatos Syslog, JSON, CEF, provenientes de endpoints, servidores y dispositivos de red.

Normalización: Conversión de datos diversos a un formato estándar para su análisis.

Correlación: Aplicación de reglas establecidas, por ejemplo:

Si se producen 5 intentos fallidos de inicio de sesión en 10 minutos desde una misma

IP → alerta crítica.

Generación de alertas

Análisis: Clasificación y priorización de acuerdo con la gravedad

Respuesta: Automatizada o manual según los procedimientos establecidos

Registro y mejora continua

Procesos de Monitoreo

Los procesos esenciales para asegurar trazabilidad y coherencia comprenden:

Recolección de eventos: Registros, alertas y métricas de diversas fuentes.

Normalización y enriquecimiento: Incorporación de información contextual como

ubicación de IP, usuario afectado y reputación de hosts.

Correlación de eventos: Aplicación de reglas basadas en MITRE ATT&CK y

comportamientos anómalos.

Generación y priorización de alertas: Clasificación basada en gravedad: crítica, alta,

media, baja.

Ejemplo de regla de correlación:

Si un endpoint identifica malware y el firewall indica conexión con una IP maliciosa

→ alerta crítica y aislamiento automático del endpoint.

Gestión de Alertas

Estrategias para mejorar la detección y disminuir el ruido operativo:

Agrupación de eventos repetidos

Supresión de alertas con bajo impacto

Clasificación por niveles de gravedad

Severidad:

Nivel Descripción

Crítica Compromiso de datos o servicios esenciales

Alta Intentos de intrusión o detección de malware

Media Anomalías sin repercusión inmediata

Baja Alertas informativas o eventos inofensivos

Herramientas recomendadas: Splunk, ELK, IBM QRadar, ArcSight.

Análisis y Respuesta a Incidentes

Procedimiento:

Validación de la alerta

Recolección de evidencias registros, capturas de memoria, tráfico de red

Clasificación del incidente acorde a su criticidad

Escalamiento al equipo de respuesta correspondiente

Implementación de acciones para la respuesta

Tipos de acciones:

Automatizadas: Bloqueo de IP, aislamiento de dispositivos, revocación de credenciales

Manuales: Análisis forense, contención avanzada, investigación de la causa raíz

Casos de Uso del SIEM

Caso 1: Intentos de acceso no autorizados

Fuente: sistemas de autenticación

Condición: múltiples intentos fallidos en breve lapso

Severidad: media

Acción: generación de alerta y notificación al usuario

Caso 2: Comunicación con IP maliciosas

Fuente: firewall y EDR

Condición: coincidencia con listas de reputación

Severidad: alta

Acción: bloqueo automático y registro del evento

Playbooks de Respuesta

Playbook: Intentos de fuerza bruta

Validación de la IP de origen

Comprobación del usuario afectado

Correlación con eventos relacionados

Bloqueo del origen del ataque

Escalamiento si el problema persiste

Playbook: Detección de malware en endpoint

Aislamiento del dispositivo comprometido

Identificación del proceso malicioso

Eliminación de la amenaza

Análisis completo del endpoint

Restauración del sistema involucrado

Visualización recomendada: Diagramas de flujo que muestran la secuencia de acciones automatizadas y manuales.

Indicadores de Desempeño

Métrica Resultado

Disminución de alertas duplicadas 40%

Reducción en tiempo de contención 35%

Falsos positivos corregidos Muchos

MTTD Tiempo promedio para detección 12 min

MTTR Tiempo promedio de respuesta 45 min

Visualización sugerida: Gráficos comparativos de las métricas antes y después de

implementar el SOC.

Simulaciones y Validación

Se llevaron a cabo simulaciones teóricas para evaluar el rendimiento del SOC:

Generación de eventos de seguridad

Activación de las reglas de correlación

Validación de las alertas

Ejecución de respuestas automatizadas

Escenarios avanzados: movimientos laterales, ataques combinados.

Ejemplo: Simulación de ransomware identificado por EDR → aislamiento automático

→ análisis forense → restauración de sistemas. Los resultados indican detección y

contención efectivas.

Evidencias del Monitoreo

Visualización de las métricas en paneles de control

Registros de alertas generadas

Documentación de incidentes de seguridad

Evidencia de acciones realizadas según los manuales de procedimientos.

Mejora Continua

Enfoque basado en:

Análisis de falsos positivos y negativos

Optimización de las reglas de correlación

Registro y seguimiento de incidentes

Retroalimentación operativa y capacitación del personal.

Riesgos y Limitaciones

Riesgo Mitigación sugerida

Dependencia de la plataforma SIEM: Redundancia y pruebas de failover.

Saturación de alertas: Priorización y optimización de reglas.

Detección de amenazas avanzadas: Integración con threat intelligence.

Necesidad de personal especializado: Capacitación y entrenamiento continuo.

Referencias

Kent, K., & Souppaya, M. (2006). *Guide to computer security log management* (NIST SP 800-92). National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-92>

National Institute of Standards and Technology. (2012). *Computer security incident handling guide* (NIST SP 800-61r2). <https://doi.org/10.6028/NIST.SP.800-61r2>

MITRE. (2023). *ATT&CK framework*. <https://attack.mitre.org>

ENISA. (2023). *Security operations centre (SOC) best practices*. <https://www.enisa.europa.eu/publications/security-operations-centre-soc-best-practices>

National Institute of Standards and Technology. (2018). *Cybersecurity framework*.

<https://www.nist.gov/cyberframework>